DAY 21 ASSIGNMENT – OWASP TOP 10:2025 — RISK IDENTIFICATION

Total Marks: 20 | Complete Assignment Answers

Student Name: Nethra M

Assignment Code: DAY 21

Topic: OWASP Top 10:2025 – Risk Identification

PART A — FUNDAMENTALS

1. What does OWASP stand for?

OWASP stands for Open Worldwide Application Security Project. It is a nonprofit organization that helps improve software and web application security.

2. What is the purpose of the OWASP Top 10?

The OWASP Top 10 identifies the most critical security risks in web applications. It helps developers and cybersecurity professionals understand and prevent common security vulnerabilities.

3. Why is the OWASP Top 10 useful for cybersecurity students?

It helps cybersecurity students understand common web application security risks, identify vulnerabilities, and learn how to protect applications from security threats.

4. What is a vulnerability?

A vulnerability is a weakness or flaw in a system, application, or network that can be exploited to compromise security.

5. What is security risk?

Security risk is the possibility that a threat may exploit a vulnerability and cause damage, data loss, or unauthorized access to a system.

6. What is an asset?

An asset is anything valuable to an organization that needs protection, such as personal information, passwords, databases, servers, and applications.

7. What is a threat?

A threat is any potential danger that can exploit a vulnerability and harm a system, network, or information.

8. What is impact?

Impact refers to the damage or consequences caused by a security incident, such as financial loss, data theft, service disruption, or privacy violations.

9. Explain Authentication.

Authentication is the process of verifying the identity of a user. For example, entering a username and password to log in to an account.

10. Explain Authorization.

Authorization is the process of determining what an authenticated user is allowed to access or perform within an application.

11. What is the difference between Authentication and Authorization?

Authentication	Authorization
Verifies the user's identity.	Checks the user's permissions.
Answers "Who are you?"	Answers "What can you access?"
Happens before authorization.	Happens after authentication.
Example: Logging in with a password.	Example: Accessing an admin dashboard.

PART B — OWASP TOP 10:2025

12. A01:2025 — Broken Access Control

Broken Access Control occurs when users can access information or functions that they are not permitted to use. For example, a normal user accessing an administrator's account or dashboard.

13. A02:2025 — Security Misconfiguration

Security Misconfiguration happens when an application or server has incorrect or insecure settings. Examples include default passwords, unnecessary services, and displaying detailed error messages.

14. A03:2025 — Software Supply Chain Failures

Software Supply Chain Failures occur when third-party libraries, software dependencies, development tools, or update systems are compromised. This can introduce malicious or vulnerable code into an application.

15. A04:2025 — Cryptographic Failures

Cryptographic Failures happen when sensitive information is not properly protected using encryption or secure cryptographic methods. This may expose passwords, personal details, and financial information.

16. A05:2025 — Injection

Injection occurs when an application processes untrusted input as commands or queries. It may allow attackers to access, modify, or damage application data.

17. A06:2025 — Insecure Design

Insecure Design occurs when an application is developed without proper security planning and controls. Missing security requirements and weak business logic can create serious vulnerabilities.

18. A07:2025 — Authentication Failures

Authentication Failures occur when an application does not properly verify user identities or manage login sessions. Weak passwords, poor session management, and missing account protection can lead to unauthorized access.

19. A08:2025 — Software or Data Integrity Failures

These failures occur when an application does not properly verify the integrity and trustworthiness of software, updates, or important data. This can allow unauthorized modifications or untrusted code to be accepted.

20. A09:2025 — Security Logging and Alerting Failures

This category occurs when applications fail to record important security events or generate appropriate alerts. Without proper logging and monitoring, suspicious activities may go unnoticed.

21. A10:2025 — Mishandling of Exceptional Conditions

Mishandling of Exceptional Conditions occurs when applications do not properly handle unexpected errors or abnormal situations. This can cause information leakage, incorrect application behavior, or security failures.

Reference: Official OWASP Top 10:2025.

top10.owasp.org+1

PART C — SAFE PRACTICAL ANALYSIS

SCENARIO 1

Situation: A normal student can access an admin-only page.

Asset:

Administrator dashboard, student records, and confidential information.

Security Problem:

A normal student has access to a restricted administrator page without proper permissions.

OWASP Category:

A01:2025 — Broken Access Control.

Possible Impact:

Unauthorized users may view, modify, or delete confidential information and perform administrative activities.

High-Level Defensive Recommendation:

Implement proper role-based access control (RBAC), verify permissions on the server side, and restrict administrator functions to authorized users only.

SCENARIO 2

Situation: A production application displays internal file paths and detailed debug errors.

OWASP Category:

A02:2025 — Security Misconfiguration.

Why:

The application is incorrectly configured to display detailed debugging information in production. This may expose internal file paths, server details, and sensitive technical information.

Recommendation:

Disable debug mode in production and display generic error messages to users.

SCENARIO 3

Situation: A company unknowingly installs a compromised third-party software dependency.

OWASP Category:

A03:2025 — Software Supply Chain Failures.

Why:

The company installs a compromised third-party dependency that may contain malicious code. This can affect the security and integrity of the entire application.

Recommendation:

Use trusted software dependencies, verify software sources, regularly update components, and monitor dependencies for security issues.

SCENARIO 4

Situation: A sensitive approval workflow was designed without an approval control.

OWASP Category:

A06:2025 — Insecure Design.

Why:

The application was designed without an important security requirement. Without an approval process, sensitive actions may be completed without proper authorization.

Recommendation:

Include approval workflows, authorization checks, and security requirements during the application design stage.

SCENARIO 5

Situation: An application does not record important suspicious authentication activity.

OWASP Category:

A09:2025 — Security Logging and Alerting Failures.

Why:

The application does not properly record or alert administrators about suspicious login activities. This makes it difficult to identify and respond to possible security incidents.

Recommendation:

Maintain security logs, monitor suspicious authentication activities, and configure alerts for unusual login behavior.

PART D — STUDENT PORTAL ASSETS

Imagine a fictional internship portal. List five important assets and explain why they need protection.

Asset 1: Student Personal Information

Why it needs protection:

Student names, email addresses, phone numbers, and personal details must be protected to maintain privacy and prevent unauthorized access.

Asset 2: Login Credentials

Why it needs protection:

Usernames and passwords must be protected to prevent unauthorized account access and identity theft.

Asset 3: Student Academic Records

Why it needs protection:

Academic details, qualifications, certificates, and marks must be protected from unauthorized viewing or modification.

Asset 4: Internship Application Database

Why it needs protection:

Internship applications, company details, application status, and student submissions must be protected to maintain confidentiality and data integrity.

Asset 5: Administrator Account and Dashboard

Why it needs protection:

Administrator accounts have special permissions to manage student information and portal settings. They must be protected to prevent unauthorized administrative access.

CONCLUSION

The OWASP Top 10:2025 helps cybersecurity professionals understand the most critical security risks in web applications. Through this assignment, I learned about vulnerabilities, threats, assets, security risks, authentication, authorization, and the ten major OWASP security categories.

I also understood how to identify security problems in fictional scenarios and recommend suitable defensive measures. This knowledge will help me improve my understanding of web application security and secure development practices.